

Report: Fine-Grained Password Policies

1. Introduction

A fine-grained password policy was created and applied on the domain controller to enforce stricter password requirements specifically for the Domain Admins group. This policy was created using the `New-ADFineGrainedPasswordPolicy` cmdlet with stricter configuration values than the default domain password policy. After creation, the policy was applied to the Domain Admins group using the `Add-ADFineGrainedPasswordPolicySubject` cmdlet. Verification was done using the `Get-ADUserResultantPasswordPolicy` cmdlet to check that the PSO was applied to the Administrator account and not to regular user accounts. This task ensured that only administrative accounts were affected by the stricter password enforcement while other user accounts continued to follow the default policy defined at the domain level.

2. Objective

The objective of these tasks was to enforce a stricter password policy for administrative accounts using a Fine-Grained Password Policy. This was done by defining a Password Settings Object (PSO) with a lower precedence value and stricter rules, assigning it to the Domain Admins group, and confirming that only Domain Admins were affected. The policy was intended to increase password complexity, length, and expiration requirements for privileged users while maintaining default settings for regular domain users. The entire process was completed and validated through PowerShell on the domain controller.

3. Tools used

- Windows Server (AD DS)
- Windows PowerShell

4. Methodology

4.1 Create a PSO (Password Settings Object) for Admins (Stricter than Default)

The PSO was created using PowerShell on the domain controller. The name assigned to the PSO was Admin_Strict_PSO. The settings configured included a minimum password length of 12 characters, complexity requirement enabled, a lockout threshold of 3 invalid attempts, a lockout duration of 30 minutes, a password maximum age of 30 days, a minimum password age of 1 day, and a password history count of 0. This allowed the current password to be reused while enforcing all other strict conditions. The following **PowerShell command** was executed:

```
New-ADFineGrainedPasswordPolicy -Name "Admin_Strict_PSO" `
-Precedence 1 `
-ComplexityEnabled $true `
-LockoutDuration (New-TimeSpan -Minutes 30) `
-LockoutObservationWindow (New-TimeSpan -Minutes 30) `
-LockoutThreshold 3 `
-MaxPasswordAge (New-TimeSpan -Days 30) `
-MinPasswordAge (New-TimeSpan -Days 1) `
-MinPasswordLength 12 `
-PasswordHistoryCount 0 `
-ReversibleEncryptionEnabled $false
```

The PSO was successfully created with no errors shown in PowerShell.

```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\Administrator> New-ADFineGrainedPasswordPolicy -Name "Admin_Strict_PSO" `
>> -Precedence 1 `
>> -ComplexityEnabled $true `
>> -LockoutDuration (New-TimeSpan -Minutes 30) `
>> -LockoutObservationWindow (New-TimeSpan -Minutes 30) `
>> -LockoutThreshold 3 `
>> -MaxPasswordAge (New-TimeSpan -Days 30) `
>> -MinPasswordAge (New-TimeSpan -Days 1) `
>> -MinPasswordLength 12 `
>> -PasswordHistoryCount 0 `
>> -ReversibleEncryptionEnabled $false
PS C:\Users\Administrator> █
```

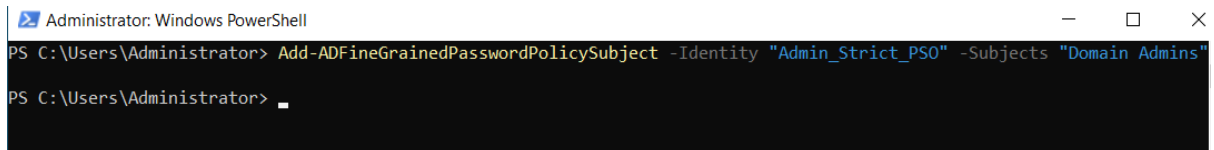
(This command creates a Fine-Grained Password Policy (FGPP) — also known as a Password Settings Object (PSO) — named Admin_Strict_PSO with stricter settings than the default domain policy.)

4.2 Apply the PSO to the Domain Admins Group

Once the PSO was created, it was assigned to the Domain Admins group using the following **command**:

```
Add-ADFineGrainedPasswordPolicySubject -Identity "Admin_Strict_PSO" -Subjects "Domain Admins"
```

This command was executed in PowerShell on the same domain controller. No error output was shown, confirming the command ran successfully. The PSO was now linked to the group, and its settings were expected to apply to all members of the Domain Admins group, including the default Administrator account.



```
Administrator: Windows PowerShell
PS C:\Users\Administrator> Add-ADFineGrainedPasswordPolicySubject -Identity "Admin_Strict_PSO" -Subjects "Domain Admins"
PS C:\Users\Administrator> _
```

(Apply PSO to Domain Admins Group)

4.3 Test Password Policy Enforcement for Admin vs. Regular Users

To verify the policy assignment, the following **command** was run:

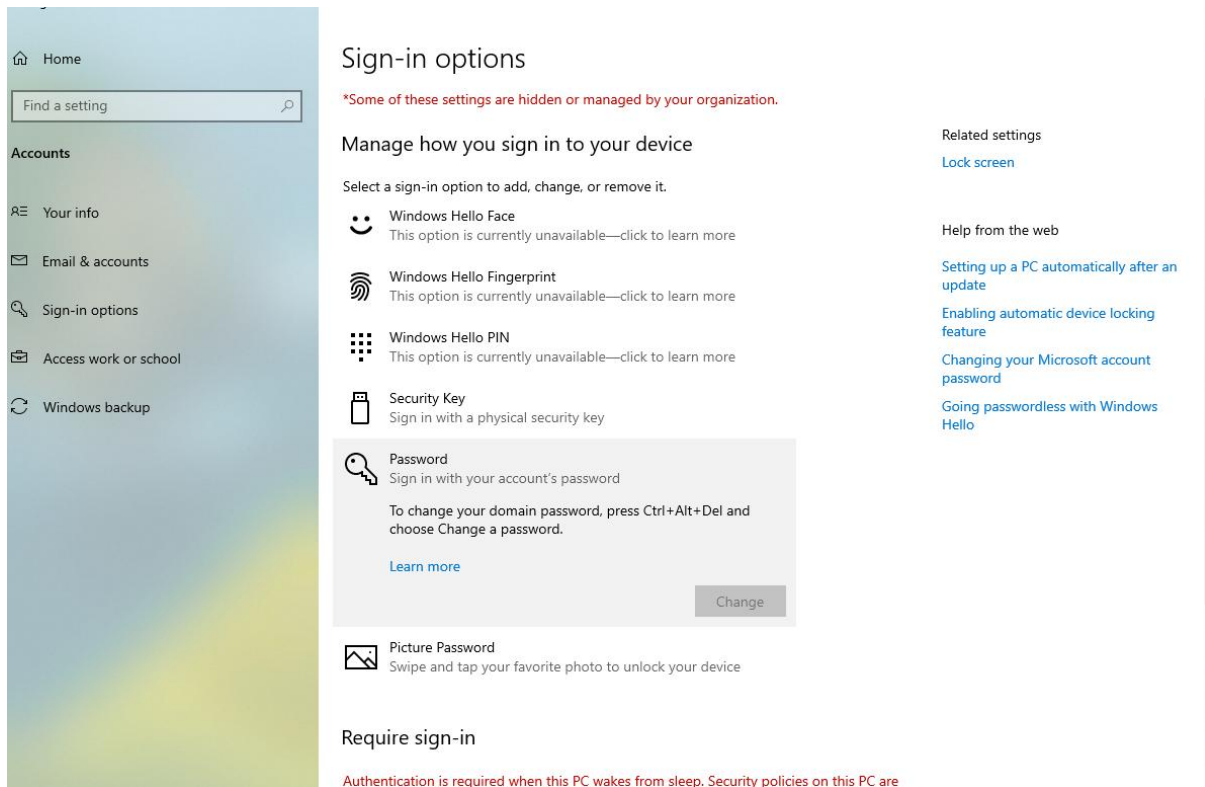
```
Get-ADUserResultantPasswordPolicy -Identity Administrator
```

The output showed that the Admin_Strict_PSO was applied. The settings matched exactly with the configuration used during PSO creation. This confirmed that the stricter policy was applied to the Domain Admins group.

Then the same **command** was run for a regular user:

```
Get-ADUserResultantPasswordPolicy -Identity Aarav.Finance
```

This command did not return any output, which confirmed that no PSO was assigned to the user and the default domain password policy was in effect.



(It confirms the device is domain-joined and password change is managed by domain policy — exactly what we expect under PSO enforcement)

5. Recommendations

- Always use `Get-ADUserResultantPasswordPolicy` to confirm PSO assignment before testing enforcement.
- Apply strict policies only to privileged groups such as Domain Admins and service accounts.
- Use unique PSO names for each policy to avoid confusion when managing multiple password policies.
- Avoid setting very high precedence numbers unless you are intentionally overriding multiple PSOs.
- Ensure that regular users remain governed by the default domain policy unless explicitly changed.

6. Conclusion

The Admin_Strict_PSO was created successfully using PowerShell with stricter rules than the default domain policy. It was then assigned to the Domain Admins group using a direct PowerShell assignment. The application of the policy was verified through the Get-ADUserResultantPasswordPolicy cmdlet, which showed the stricter policy being applied to the Administrator account. The same command returned no output for a regular user, confirming that the PSO did not apply to them. All tasks were completed using PowerShell on the domain controller.